

Email Analysis (SOC Perspective)

Email analysis = process of investigating an email to check if it's **legitimate, spam, or malicious** (phishing, malware, spoofing, etc.).

It's one of the **most common tasks for SOC analysts**.

Key Points in Email Analysis

When you get a suspicious email, you should check:

1 Email Headers

Headers contain **hidden technical details** about the journey of the email.

Things to check:

- **From** → Who the sender claims to be.
- **Return-Path** → The actual address where replies go (may be different).
- **Received** → Shows the servers the email passed through (trace the origin).
- **SPF/DKIM/DMARC results** → Did it pass authentication?
- **Message-ID** → Helps identify the real sending domain.

 **Red flag:** Sender claims to be from paypal.com but the "Received from" IP belongs to some unknown server.

2 Subject & Body

Look for:

- Urgent or threatening language ("Your account will be suspended today!").
- Spelling/grammar errors.
- Fake links (hover mouse over link → see real URL).

 **Red flag:** A link says <https://bank.com> but really goes to <http://badwebsite.ru/login>.

3 Attachments

Check if:

- Attachment has strange extensions (.exe, .js, .vbs, .scr).
- Even if it looks safe (.pdf, .docx), it could contain **macros or exploits**.
- Always scan with tools (VirusTotal, sandbox).

 **Red flag:** Unexpected invoice attachment from unknown sender.

◆ What are Macros?

- A **macro** is a small program/script that automates tasks inside applications like **Microsoft Word, Excel, PowerPoint**.
- Normally used for **legit automation** (like formatting, calculations, templates).
- But attackers abuse macros to **deliver malware**.

 Example:

- You get an email with an attachment: Invoice.docx
- Inside, the attacker hides a malicious **VBA macro**.
- When you **open and enable macros**, the script runs and:
 - Downloads malware from the internet

- Creates a backdoor (reverse shell)
- Steals passwords

⚠ That's why SOC Analysts always warn: "Do NOT enable macros in suspicious documents."

◆ What are Exploits?

- An **exploit** is code or a method that takes advantage of a **software vulnerability (weakness/bug)**.
- Exploits let attackers **bypass security** and **execute malicious actions**.

👉 Example:

- A PDF reader has a **buffer overflow bug**.
- Attacker crafts a **malicious PDF**.
- When the user opens it, the exploit triggers → gives attacker control of the system.

Types of Exploits:

1. **Local Exploit** → Needs access to the system (privilege escalation).
2. **Remote Exploit** → Attacker runs code over the network (like via a malicious website/email).
3. **Zero-Day Exploit** → Targets a vulnerability **not yet patched** by the vendor.

◆ Key Difference (Macros vs Exploits)

Feature	Macros 📄	Exploits 🛠
Where it runs	Inside Office apps (Word, Excel)	Any vulnerable software (OS, browser, apps)
Needs user action?	Yes → victim must enable macros	Sometimes no (can run automatically)
Attack method	Runs malicious script	Leverages software vulnerability
Common delivery	Phishing email attachments	Malicious websites, files, unpatched apps

4 Links/URLs

- Hover over links (don't click).
- Look for misspelled domains (micros0ft.com, paypai.com).
- Use online tools: **VirusTotal**, **URLScan.io**, **PhishTank**.

5 Sender Reputation

- Check sender's domain with tools like **Whois lookup**.
- New domains or free email providers (Gmail, Yahoo) sending "official" mails = suspicious.
- Cross-check with threat intelligence feeds (MISP, AlienVault OTX).

6 SPF, DKIM, DMARC

- Check if the email **passed authentication**.
- If **fail** → very high chance of spoofing.

7 Attachments & Payload Extraction (Advanced SOC step)

- Open in **sandbox environment** (not normal system).
- Analyze with tools like **Cuckoo Sandbox**, **Any.Run**, **Hybrid Analysis**.
- Check for **indicators of compromise (IoCs)** → IPs, domains, hashes.

◆ Step-by-Step Email Analysis Example

Imagine an email says:

From: support@paypal.com

Subject: Your account locked

Click here to login: <http://secure-paypal-login.xyz>

Analysis:

- **From header:** Looks like PayPal, but "Received from" IP → unknown.

- **SPF/DKIM/DMARC:** Fail.
- **Link:** Not PayPal domain.
- **Language:** Urgent + fear tactic.

👉 Verdict: **Phishing email** 🚨

✅ **Summary for SOC Analysts**

When analyzing emails, always check:

1. **Headers** (origin, SPF/DKIM/DMARC).
2. **Body & subject** (language, urgency, links).
3. **Links & domains** (hover, scan).
4. **Attachments** (scan, sandbox).
5. **Sender reputation.**
6. **Extract IoCs** (IP, domains, hashes) for further hunting.